



BMK FINANCIAL SERVICES · CLIENT DATA PROTECTION

Security & Data Protection Report

*How the BMK CRM platform protects client financial information
— from the first word a client says to Sarah, to the signed
Statement of Advice.*

PREPARED FOR

Brad Lonergan, BMK Financial Services

DATE

July 2026

PLATFORM

BMK CRM — AI-powered client onboarding &
advice pipeline

SCOPE

Encryption, access control, audit, privacy
compliance

Client data is encrypted before it is stored, gated behind adviser sign-in, and every action leaves a permanent record.

A financial planning practice holds the most sensitive information a client will ever share: income, debts, superannuation, insurance, health, and family circumstances. The BMK CRM platform was built on the assumption that this data will be attacked, and that the practice must be able to prove — to a client, a licensee, or a regulator — exactly how it was protected and who touched it.

The three commitments

- 1. Nothing is stored readable.** Every client record is encrypted by the platform itself with AES-256-GCM — the same cipher class used in banking — *before* it reaches any database or disk. Someone who steals the entire database gets ciphertext and nothing else. If an encryption key is not configured, the platform refuses to save client data at all rather than save it unprotected.
- 2. Nobody gets in without proving who they are.** Every adviser page and data endpoint sits behind sign-in with optional two-factor authentication from an authenticator app. Five failed attempts lock the account for fifteen minutes. Clients never need accounts — each client onboarding session runs on its own private link.
- 3. Everything leaves a trail.** Compliance actions, sign-ins, failed logins, and lockouts are appended to an encrypted, append-only event log — a permanent history that an ASIC or licensee review can reconstruct years later.

Security posture at a glance

CONTROL AREA	STATUS	IN ONE LINE
Encryption at rest	LIVE	AES-256-GCM applied by the application; tamper-evident; verified against the stored files.
Fail-closed storage	LIVE	No encryption key configured means no client data is written. Ever.
Adviser authentication	LIVE	Password + authenticator-app code, lockout on brute force, 12-hour sessions.
Durable audit trail	LIVE	Encrypted, append-only record of compliance and security events.
Rate limiting	LIVE	Every public endpoint throttled per source to blunt abuse and credential stuffing.
Privacy notice (APP 5)	LIVE	Collection notice shown to every client before their discovery session begins.
Multi-adviser & SSO	ROADMAP	Current sign-in is single-adviser; SSO planned before multi-firm rollout.
Independent penetration test	ROADMAP	Recommended before onboarding external firms.

Defence in depth: five layers between an attacker and a client's file

No single control is trusted to hold. Each layer assumes the one in front of it has already failed.

LAYER	WHAT IT DOES	WHAT IT DEFEATS
1 · Transport	All traffic served over HTTPS (TLS) via Vercel's edge network. Session cookies are HttpOnly, SameSite, and Secure — invisible to page scripts.	Eavesdropping on café Wi-Fi; cookie theft via injected scripts.
2 · Access	Middleware gate on every adviser page and API. Signed 12-hour sessions; two-factor codes from an authenticator app; uniform error messages that never reveal whether an email exists.	Stolen passwords used alone; account probing; forgotten logged-in tabs.
3 · Abuse control	Per-source rate limits on sign-in, the client discovery session, transcription, and every write endpoint. Fifteen-minute lockout after five failed sign-ins, with each attempt logged.	Brute-force and credential-stuffing attacks; runaway API abuse and its costs.
4 · Storage	Field-level AES-256-GCM encryption applied by the application before data reaches Postgres or disk. GCM authenticates as it encrypts, so an altered record fails loudly instead of returning corrupted data. Refuses to operate unencrypted in production.	Database theft; backup leaks; a compromised or curious hosting provider; silent tampering.
5 · Audit	Append-only encrypted event log for compliance actions and security events, stamped with actor, timestamp, and the rules version in force at the time.	"Who changed this and when?" going unanswered in a dispute, licensee review, or ASIC inquiry.

The client's journey, protected end to end

A client opens their private onboarding link and — before a single question is asked — sees a privacy collection notice covering purpose, disclosure, and their access and complaint rights under the Privacy Act. Their conversation with Sarah travels over TLS. The completed fact find is encrypted the moment it arrives and stored as ciphertext. When Brad reviews it the next morning, he signs in with his password and authenticator code; the platform decrypts the record for his session, and the compliance check he runs is written into the permanent audit trail. At no point does readable client data sit on a disk, in a backup, or in a database console.

Encryption & storage

Application-level AES-256-GCM

Encryption happens inside the platform, not in the database. The database provider — whether Neon, Supabase, or Vercel Postgres — only ever receives an opaque envelope (`enc1....`) containing the initialisation vector, authentication tag, and ciphertext. This is a materially stronger position than "the database is encrypted": it protects against the provider itself, against misconfigured backups, and against anyone reading the database directly.

VERIFIED IN TESTING

The stored data files were inspected byte-for-byte after live use: they contain only `enc1` ciphertext envelopes. No client name, figure, or answer appears anywhere in storage.

Tamper evidence

GCM is an *authenticated* cipher: it detects modification as well as hiding content. A record altered by even one bit fails decryption with an explicit error rather than silently returning wrong financial figures — the failure mode that matters most when the data feeds a Statement of Advice.

VERIFIED IN TESTING

A stored record was deliberately corrupted; the platform rejected it loudly and continued serving the surrounding healthy records.

Fails closed, never open

If the encryption key is absent in production, the platform refuses to accept client data — the save returns an error and nothing touches disk. A misconfigured deployment can never quietly accumulate unencrypted files.

VERIFIED IN TESTING

A production server was started with no key configured. The save endpoint returned "Data was not saved" and the storage directory remained empty.

Durability across restarts and deploys

Encrypted records are rehydrated into the running platform at every boot, so completed fact finds survive server restarts, redeployments, and infrastructure moves. The same layer runs against Postgres in production and encrypted local files in development — identical security properties in both.

VERIFIED IN TESTING

A fact find was saved, the server was killed and restarted, and the record was retrieved intact — decrypted from storage, not from memory.

Access, abuse control & audit

Adviser sign-in with two-factor authentication

- Passwords are stored only as **scrypt** hashes — a deliberately expensive algorithm designed to make cracking stolen hashes impractical — and compared in constant time.
- Optional **authenticator-app codes** (Google Authenticator, Authy, 1Password) using the same TOTP standard as the major banks.
- **Five failed attempts lock the account for fifteen minutes**, and the lockout itself is written to the security log.
- Error messages are identical for a wrong email and a wrong password, so an attacker cannot discover which emails have accounts.
- Sessions are cryptographically signed, expire after twelve hours, and live in cookies that page scripts cannot read.

VERIFIED IN TESTING

The full flow was exercised live: unauthenticated visits redirect to sign-in; API calls without a session receive 401; wrong passwords and wrong authenticator codes are rejected; the sixth failed attempt triggers the lockout; a correct password plus a correct code issues a working session.

Clients never need passwords

Client onboarding runs on private per-session links, so clients face no account creation and no password to lose. The endpoints Sarah needs stay public and rate limited; everything that *reads* client data back requires an adviser session.

Rate limiting on every public surface

Sign-in attempts, fact-find submissions, Sarah conversation turns, voice transcription, and audit writes are each throttled per source address. This blunts brute-force attacks and protects against abuse of the platform's paid AI services.

A permanent, encrypted audit trail

Two event streams are appended to encrypted, append-only storage: **compliance events** (checks run, blockers resolved, certificates generated, adviser sign-offs — each stamped with the compliance-rules version in force) and **security events** (sign-ins, failures, lockouts, sign-outs, with source address and timestamp). Records can be added but not rewritten — the property a regulator looks for in an audit trail.

VERIFIED IN TESTING

Failed sign-ins and lockouts were confirmed landing in the encrypted event store, retrievable after a server restart.

Where this lands against Australian obligations

OBLIGATION	HOW THE PLATFORM ADDRESSES IT
Privacy Act — APP 5 Notification of collection	Every client sees a plain-language collection notice on the onboarding screen before any question is asked: what is collected, why, who it is disclosed to, and how to access, correct, or complain (including the OAIC pathway).
Privacy Act — APP 11 Security of personal information	"Reasonable steps" is met with encryption at rest, authenticated access, abuse controls, and logging — controls proportionate to the sensitivity of full financial fact finds.
Corporations Act Record-keeping, s912G / RG 175	The append-only audit trail preserves who did what and when, stamped with the compliance-rules version — supporting reconstruction of best-interests-duty evidence years later.
Licensee obligations Charter, AFSL 234665	Compliance checks, sign-offs, and certificates flow through the audited pipeline, giving the licensee a queryable history rather than a filing cabinet.
Notifiable Data Breaches Part IIIC, Privacy Act	Encryption materially changes breach analysis: stolen ciphertext without the key is generally not "likely to result in serious harm". The security event log supports rapid assessment of what happened.

An honest answer to "is it compliant?"

The *technical* controls now in place meet or exceed what APP 11 asks of a practice this size, and the audit design directly serves Corporations Act record-keeping. But security compliance is never a finished state, and two categories remain open:

- **Operational practices** — key custody (the encryption key held in a password manager Brad controls), a written data-breach response plan, and a backup/recovery routine. These are procedures, not code.
- **Independent assurance** — before other firms put their clients' data on the platform, an external penetration test and privacy review is the professional standard, and would be expected in any licensee's due diligence.

Roadmap

ITEM	WHY	WHEN IT MATTERS
Multi-adviser accounts & SSO	Per-user identity and permissions	Before any second adviser or firm joins
Shared rate-limit store	Consistent limits across servers	When traffic needs multiple instances
Key rotation tooling	Re-encrypt under a new key in place	Annual hygiene, or on key exposure
External penetration test	Independent validation of all of the above	Before multi-firm rollout

Prepared July 2026 from the implemented codebase of the BMK CRM platform (repository: Brads-Finance-Revolution). Every control marked "Verified in testing" was exercised against a live build during implementation, not inferred from design documents. Configuration steps for production activation are documented in SECURITY.md within the repository.